

Samana QMS: response to the independent code review

Response dated 22 September 2026 · Review dated 21 September 2026 (reviewed commit d2f6a31) · Code as of commit 500caae (22 September 2026) · Written for management and engineering

Verdict: the code is production-ready. Every defect the review found that is real is fixed and covered by an automated test. What remains open is not code: four routing-policy questions for the business, two identity questions for IT, and the production hosting steps.

The review was written against the code of 21 September, 11:04. Since then the codebase has changed substantially in direct response to it: seven commits, a real Next.js runtime, a declared API route table, a connection pool with transactions, push updates instead of polling, a restricted database role, a retention job, an alert endpoint, and a move to the standard PostgreSQL driver. This document takes the review section by section, states whether each finding was valid, shows what changed, and names the test that now guards it.

13 review sections	9 valid and fully closed in code	2 partly wrong; the valid part closed	2 policy, not defects (decisions listed)
147 automated tests, all passing	3 environments verified: local PostgreSQL 18, Neon, live Render		

Status labels used below: Closed fixed before this response and verified · Closed today fixed in this response · Not a defect the claim does not hold, with the evidence · Decision a business or IT choice, not a code fault · Operations a launch step outside the code.

Scorecard

§	Reviewer's headline	Status	Where it stands now
01	Missing structure in six places	Closed	Modules per feature, one schema definition with a drift test, declared permissions, one roles definition, an enforced browser/server boundary. The single lock is kept and now measured (§07).
02	No backend; one 497-line file; access by line order	Closed / Not a defect	Route table with declared access and verbs, per-resource handlers, scheduler death visible. The claim that assignment only happens when the scheduler calls was wrong: check-in routes in the same transaction.
03	No Prisma, no database layer	Closed / Decision	Connection pool and transactions exist. Business rules stay in PostgreSQL functions by decision, with a searchable snapshot, column checks and 20 workflow tests. An ORM was considered and declined; reasons in §03.
04	Migrations compound it	Closed	Checksums, numbered files only, one current definition of every function, parser and filter tested. Forward-only policy documented instead of down migrations.
05	Not built on Next.js	Closed	Real Next.js 16.3.5, standalone output, browser protections in <code>proxy.ts</code> , verified live.
06	Neon serverless is the wrong choice	Closed / Operations	Standard PostgreSQL driver; the same build runs on the company's PostgreSQL 18 server today. Render moves off Neon when the production server exists.
07	No push; one lock; 105 s to notice a dead agent	Closed / Closed today	Push via server-sent events; plain-language errors; dead agent noticed within 45 s and re-routed within 60 s (was 90 and 105). Lock kept: measured under load in this response.
08	Roles from nowhere; list in 24 places	Closed / Decision	One roles definition in code, validated Salesforce ids, guest accounts purged, sign-in audited, bootstrap password now pages the monitor. SSO or MFA is an IT decision.
09	No consistent standard, front or back	Closed	Every row of the reviewer's table is fixed; error boundaries added today. Two cosmetic items remain (three CSS files, no browser tests).
10	How a customer is given to staff	Decision	The rules implement the BRD. Four fairness questions are listed for the business with a recommendation each; one claim ("nobody else can pick them up") is wrong.
11	Screen by screen	Closed / Closed today	Of 33 screen findings, 29 are fixed, 2 were not defects, 2 are device tests. Table in §11.
12	690,000 idle database questions a day	Closed	Screens now sit on a push stream. Idle load per staff screen fell from 72 to 16 database queries a minute, and a change reaches every screen in under a second instead of up to five.
13	Salesforce outage stops check-in; sign-in never recorded	Closed	Walk-in fallback, circuit breaker, lookup reuse, sign-in and presence audited, audit paging with filters and export.

§01 The findings in one page

Structure would give you	Review said	Now	Guarded by
Features in their own place	One file for the back end, one for the front end	Closed API handlers live in <code>lib/api/</code> per resource; the workspace shell is split into views and hooks that load on demand.	<code>tests/routes.test.ts</code> , <code>tests/boundary.test.ts</code>
Mistakes caught before a customer sees them	No master description of the data	Closed <code>db/schema.sql</code> is generated from the database and compared on every test run; a test also checks that every column the API selects exists. TypeScript is strict.	<code>tests/schema.test.ts</code>
One current version of each rule	Six rules with two to four live versions	Closed The snapshot holds the one current definition of every function. Applied migrations are checksummed and cannot be edited.	<code>tests/schema.test.ts</code> , <code>scripts/migrate.mjs</code>
Boundaries so one slow job cannot stall the rest	A single lock shared by every action	Decision Kept, and measured under load in §07: with 200 customers waiting the tick holds the lock for 96 to 214 ms.	<code>scripts/load-check.mjs</code>
One definition of each concept	Roles hand-copied into 24 places	Closed Roles and role groups are defined once in <code>lib/domain.ts</code> and <code>lib/api/shared.ts</code> . The database keeps one check constraint and its function bodies, all visible in the snapshot.	<code>tests/routes.test.ts</code> , workflow tests
Permissions declared once, per feature	Access depends on the line a feature was pasted at	Closed Every route declares method, path and who may call it. A test pins the exact set of unauthenticated and guest-reachable routes, so a new route is closed by default.	<code>tests/routes.test.ts</code>

On the review's note that the project's own "Security and code review" is not independent assurance: agreed. This response is also written by the developer. Everything in it can be reproduced with the commands in the Verification section.

§02 There is no backend

Claim	Status	Evidence
The whole API is one 497-line file matched by comparing text	Closed	<code>lib/router.ts</code> dispatches a declared table; handlers are grouped in <code>lib/api/auth.ts</code> , <code>tickets.ts</code> , <code>queue.ts</code> , <code>team.ts</code> , <code>reports.ts</code> , <code>public.ts</code> , <code>events.ts</code> . Path parameters are matched by the router.
Whether an action needs a login depends on which line it sits at	Closed	Each route states <code>public</code> , <code>worker</code> , <code>session</code> or a role list. The dispatcher enforces origin, bearer, session, forced password change and role before any handler runs.
The notifications endpoint has no permission check	Closed	<code>PATCH /api/notifications</code> requires a staff role; a guest session is refused (test "refuses notification changes from a guest session").
Only GET and POST exist	Closed	PUT for presence, password and team edits, PATCH for notifications, DELETE for queue membership.
Assignment only happens when the scheduler phones in; if it stops nobody is called	Not a defect	This was wrong when written. <code>qms.issue_ticket</code> calls <code>qms.route_ticket</code> in the same transaction, so a customer is assigned at check-in (workflow test "routes an available unit owner directly"). The scheduler only re-routes after five minutes and expires stale presence.
If the scheduler dies nothing raises an alarm	Closed	The staff queue shows a banner after 90 s; <code>GET /api/health/scheduler</code> and <code>GET /api/health/alerts</code> return 503 for an uptime monitor.
A second service phones the website every 15 s over a shared password	Closed today	The Render worker now runs the tick directly against the database (<code>render.yaml</code>): no HTTP hop and no shared secret. The web endpoint remains for hosts that can only run a cron caller.
The boundary is a naming convention; a wrong import is all it takes	Closed today	Next.js already refuses to bundle Node-only modules into browser code. <code>tests/boundary.test.ts</code> now makes it a rule: browser code may import only the three client-safe modules, and only the API entry point may import the route table.

Why the API stays inside Next.js for now

The review argues for a separate backend service. Every benefit it lists is now present without one: background work runs in its own worker process, screens receive push updates, the database is pooled with transactions, every client uses the same HTTP API, web and worker deploy as separate services, and the browser/server boundary is enforced by the bundler and a test. What a separate service would add is an independent deploy cadence for the API and a second team's autonomy. For one centre and one developer that is cost without value: a third always-on service, a shared cookie domain, and more places for secrets. The route table takes a standard request and returns a standard response, so extracting it behind a small Node server under the same `/api` path is a two-to-three-day task. The trigger is written in the design document: a second client, a second centre, or a second team.

§03 No Prisma, no database layer

Claim	Status	Evidence
A new connection per query; no pool; no transactions	Closed	<code>lib/db.ts</code> keeps a pool of ten connections over the standard PostgreSQL protocol and offers <code>transaction()</code> with BEGIN, COMMIT and ROLLBACK. Guest creation and migrations use it.
Query results are asserted, not checked	Closed	The columns each API query selects are checked against the live schema in <code>tests/schema.test.ts</code> ; the database snapshot fails the build when it drifts.
Business rules live in the database because the driver forced it	Decision	They live there because issuing a ticket must number it, insert it, route it and notify screens as one unit under one lock, and PostgreSQL is the only place that can guarantee that for every caller. That was a design choice and it stands with a real pool available.
Rules cannot be type-checked, searched, reviewed or tested	Closed	Searched and reviewed: <code>db/schema.sql</code> holds the current text of every function. Tested: 21 workflow tests call the functions directly (routing, five-minute boundary, escalation, idempotency, duplicate visits, rollover, retention). Type-checked at the boundary: the API document and column check.
Use Prisma	Decision	Declined. An ORM would add a second schema definition to keep in step, would still need the functions for atomic numbering and routing, and would not change any test. The reviewer's causal chain (no ORM causes the lock, the migrations and the polling) does not hold: polling is gone, migrations are checksummed and snapshotted, and the lock is a routing design that an ORM does not remove.

§04 The migrations compound it

Claim	Status	Evidence
Rules rewritten across files, none marked current	Closed	<code>db/schema.sql</code> is the current state, generated from the database. Migrations remain the history. A fresh database built from the migrations alone produces a snapshot identical to the file (verified on the local PostgreSQL 18 server).
No checksums; an edited migration is silently skipped	Closed	The runner stores a SHA-256 of each applied file and refuses to start when one was edited.
The runner would happily run anything	Closed	Found while re-testing: the runner picked up every <code>.sql</code> file, including the snapshot, and would have failed the Render pre-deploy step. It now applies numbered files only (test "applies only numbered migration files").
No down migrations	Decision	Forward-only by policy, documented in operations: migrations are additive, the app rolls back independently, and a schema defect gets a reviewed forward fix. Down migrations are rarely tested and give false comfort; a rehearsed restore is the real safety net and is on the launch list.
A hand-written SQL parser with no tests	Not a defect	Two parser tests existed when the review was written; a third now covers the file filter. The parser handles quotes, comments and dollar-quoted bodies, and each file applies in one transaction.
Migration 001 had the wrong role list	Closed	Corrected by 002 the same day; the snapshot shows the single current constraint with all seven roles.

§05 It is not built on Next.js

Closed The beta framework is gone. The project runs on Next.js 16.3.5 with standalone output; the same artifact runs on Render, in Docker and on a laptop. Browser protections live in the framework's supported `proxy.ts` and the static headers in `next.config.ts` are defence in depth for assets served without the proxy, not uncertainty. Verified on the live site: Content-Security-Policy, HSTS and frame denial present, unknown paths 404, hidden paths 404. The Cloudflare and OpenAI deployment targets were deleted, so there is one production path.

§06 Neon serverless is the wrong choice

Claim	Status	Evidence
A serverless database is the wrong shape for a system that never sleeps	Closed / Operations	The code uses the standard <code>pg</code> driver and runs on any PostgreSQL 14 or newer. Development and test databases now live on the company's PostgreSQL 18 server; the full suite and an end-to-end smoke test pass there. Render keeps Neon only until the production server exists, and the move is one dump and restore.
Every query is its own internet request	Closed	Connection pool; a sign-in is one connection, not six requests.
2,300 database queries a minute at rest	Closed	Screens sit on a push stream and poll only as a 30-second safety net. See §12 for the numbers.
No retry logic anywhere	Not a defect	Deliveries to Salesforce and SMS retry with exponential backoff up to five times; Salesforce lookups are protected by a circuit breaker with a walk-in fallback; the pool reconnects. A blind retry of an arbitrary query is not added because most writes are not safe to repeat.
The driver cannot hold a transaction open	Closed	It can now; <code>transaction()</code> in <code>lib/db.ts</code> .

§07 One queue, many people

Claim	Status	Evidence
Nobody is told anything; every screen asks on a timer	Closed	Migration 013 raises a PostgreSQL NOTIFY on every ticket, notification or availability change; the web server relays it over server-sent events to every open screen, which refresh within about 300 ms. Verified end to end on the local server, on Neon and on Render.
Alerts are in-page toasts only; background tabs miss them	Closed	Desktop notifications on assignment, plus the push stream which browsers do not throttle like timers.
"version conflict" shown raw to a receptionist	Closed	Database rule codes map to plain sentences ("This ticket was just updated by someone else..."), with the code kept for support (test "explains a version conflict in plain words").
A dead laptop keeps receiving customers for up to 105 seconds	Closed today	Heartbeat every 15 s, availability window 45 s (migration 015). An agent whose screen died stops receiving customers 45 s after the last heartbeat, and the tick moves their waiting customers on within 15 s more: worst case 60 s, typical 50 s. The review's 105 s was also overstated for the old code: assignment already checked the heartbeat at assignment time, so the old worst case was 90 s to stop and 105 s to re-route. Test "stops handing customers to an agent silent for more than 45 seconds".
One lock for everything; with 200 waiting the tick blocks the building	Decision , measured	Measured on the company's PostgreSQL 18 server with <code>scripts/load-check.mjs</code> : 200 customers checked in at once from 20 connections in 1.3 s (about 150 check-ins a second, each waiting its turn for the lock); the routing tick with 200 waiting customers and 20 agents online held the lock for 96 ms, and with 400 waiting and 10 agents for 214 ms; 1,200 call, start and close actions by 10 agents working in parallel, with heartbeats firing every second, completed at a median of 11 ms and a 95th percentile of 20 ms. A centre with twenty counters produces perhaps one action a second; the lock is idle more than 98% of the time. The lock is a correctness device (no two agents ever own the same customer, ticket numbers never collide) and at this scale its cost is milliseconds. It is revisited only if a load test at the real number of counters shows contention; the design document records the trigger.

§08 Where do user and admin roles come from?

Claim	Status	Evidence
No SSO, no MFA, no link to HR	Decision	Correct and unchanged: an identity provider is an IT choice (Microsoft Entra or Salesforce). Until then: PBKDF2 at 600,000 iterations, hashed sessions, forced password change, rate limits, sign-in and sign-out audited.
Access survives until someone remembers to switch it off	Decision	Disabling an account ends its sessions immediately and is audited. An automatic link to HR needs the identity provider above.
Nothing enforces removing the bootstrap password	Closed today	Settings already warned; in production the alert endpoint now reports <code>bootstrap_password_present</code> , so the uptime monitor pages until it is removed (test "pages the monitor while the bootstrap password is still on a production host").
Salesforce id is free text; a typo routes to nobody	Closed	The id must match the Salesforce user-id pattern and is normally filled from the Salesforce search.
Customer accounts are created per scan and never deleted	Closed	Guest accounts that never issued a ticket are purged after a day; identifiers on closed tickets are anonymised by the retention job once a period is set.
The role list is hand-copied into 24 places	Closed in code	TypeScript has one definition of roles and three role groups. Adding a role is one constant plus one migration for the database constraint. The role lists inside database functions remain, are visible in the snapshot, and are exercised by the workflow tests.
The whole application is downloaded regardless of role	Closed	Team, Queues, Reports, Settings, TV and Audit load on demand. The server-side checks were always the protection, and they are now declared per route.

§09 No consistent standard

Observation	Status	Now
Whole back end in one function (497 lines)	Closed	Route table and seven handler modules.
Whole front end in one component (1,447 lines)	Closed	Shell split into login, queue table, audit, data hooks and lazy views; error boundaries added today so one failing view cannot blank the workspace.
47 unused interface components shipped	Closed	54 removed; 7 remain, all used.
shadcn as a runtime dependency	Closed	Development dependency only.
<code>wrangler dev</code> as the production start command	Closed	Removed; <code>npm start</code> runs the standalone server that Render and Docker run.
Four deployment targets, none verified	Closed	Two remain (Render and Docker), both verified.
No real page routing, no 404	Closed	Unknown views and hidden paths return 404.
OneDrive workaround in the production build	Closed	Build runs in place.
CI runs a test file that does not exist	Closed	CI runs the unit tests by name and the full suite against a PostgreSQL 18 container on every push and pull request, with no external secret.
Remaining	Decision	Three CSS files (cosmetic, no functional risk) and no browser tests (device acceptance covers the same ground before launch).

§10 How a customer is given to a staff member

These findings describe the routing policy the BRD asked for, not defects. They are real trade-offs and deserve a decision. One statement is wrong: "nobody else can pick them up". A manager or HOD can reassign any ticket at any time, and the five-minute rule re-routes automatically.

Observation	What the system does	Recommendation	Who decides
Work at one counter counts for nothing at another	Round robin per service, as specified.	Optional cross-service fairness: pick the eligible agent with the fewest customers handled today across all services. One day of work when agreed.	CRM and Collection managers
A newly added member jumps the queue	New members start at the front of the rotation.	Start new members at the back. Half a day.	Same
One agent can be given ten waiting customers	Assignment happens at check-in so the customer sees a counter immediately, as specified; the agent becomes busy on call. The tick re-routes anything uncalled after five minutes.	Optional cap on uncalled assignments per agent, or assignment at call time. One day.	Same
The customer's own relationship manager always wins	Preferred owner first, as specified.	Keep, or add a threshold above which the owner is skipped. Half a day.	Same
Nothing can be marked urgent	Not in the BRD.	A priority flag on the ticket honoured by routing and the TV. One to two days.	Product
A customer left with someone who has gone waits more than five minutes	Since today: a vanished agent stops receiving customers after 45 s and their customers move on within 60 s; the queue shows the routing reason.	Closed by §07. A supervisor banner for tickets uncalled beyond a threshold is a small addition if wanted.	Product
The admin cannot set any of these	Correct: they are code, not settings.	Once the policy is decided, expose the chosen knobs on the Routing rules page.	After the decisions above

§11 Screen by screen

Screen	Finding	Status
Check-in	Registered customer with no units cannot check in	Closed served as General Query
	Arabic half-translated	Closed
	Right-to-left on one box only	Closed page direction and language follow the choice
	Language not remembered	Closed
	Privacy note misleading	Closed text corrected; retention job anonymises identifiers once a period is set
Customer's phone	Polls forever after the visit ends	Closed stops on close, no-show or expiry
	Token in the address	Not a defect the invite is a signed, five-minute, single-purpose link over HTTPS; this is how QR check-in works
	"N ahead" counts everyone in the service	Not a defect the query counts only waiting tickets created earlier
	Keeps polling a dead link	Closed
Reception TV	Expired session shows "Reconnecting" forever	Closed shows a sign-in message
	Sound off by default, not remembered	Closed remembered per TV
	The ticket showing at load is never announced	Closed today announced when sound is on; browsers may still require one click after a reload before speech is allowed
	Polls every 3 s, fetches 12 shows 7	Closed push stream, fetches exactly 7
Staff queue	1,447-line component	Closed
	In-page alerts only	Closed desktop notifications
	Timer rebuilt on every keystroke	Closed one stable interval
	Any address returns a page	Closed real 404
Ticket drawer	Never refreshes; stale version	Closed refreshes every 5 s while open
	Downloads the staff list every time	Closed fetched only when reassigning
Team administration	Salesforce id free text	Closed pattern-validated
	Admin types temporary passwords	Closed generator with show/hide
	Accounts never deleted, no paging	Not a defect staff rows are referenced by the audit trail and must survive; disable is the correct operation; the list is tens of people
	Roles shown as system words	Closed job titles
	Disable without confirmation; banner never disappears	Closed
Queue administration	Removing the last member allowed silently	Closed confirmation and empty-queue warning
	Every change reloads the page data	Not a defect the data is a few dozen rows; a bulk-add is a convenience, not a fault
Reports	Export puts identifiers into a spreadsheet	Closed today identifiers leave the system only when the manager ticks the option, and every export is recorded with its filters

	Oversized exports fetched then rejected	Closed counted first
Settings	No confirm field; signs out everywhere	Closed confirmation field and explanation
	"Queue policies" looks like settings	Closed renamed Routing rules, described as fixed
	Scheduler panel says five minutes	Closed text states 15-second checks and the five-minute rule
Printed receipt	Print dialog can open on an empty receipt	Not a defect the print button only renders after the receipt has loaded
	Never tested on real hardware	Operations device acceptance before launch

§12 What the system does when nobody is using it

Closed Screens no longer ask every few seconds. Each staff screen holds one push connection and refreshes only when the database says something changed; a 30-second poll remains as a safety net, and a 15-second availability heartbeat keeps the agent marked present.

Per idle staff screen	Before	Now
Requests to the server per minute	14 (queue every 5 s, heartbeat every 30 s)	6 (queue every 30 s, heartbeat every 15 s)
Database queries per minute	74	16
Per 8-hour shift	35,500 queries	7,700 queries
Time for a change to reach the screen	up to 5 s	under 1 s
Reception TV	40 queries a minute	4 a minute plus the stream
Twenty staff and two TVs, idle day	about 750,000 queries	about 160,000 queries

The review's 690,000 assumed twenty televisions; the table uses two.

§13 Every Salesforce call, and everything recorded

Claim	Status	Evidence
If Salesforce is unreachable nobody can check in, not even a walk-in	Closed	Staff can register a walk-in without Salesforce; the lookup event is marked <code>degraded</code> so the visit can be matched later. Guests still need the lookup, by design.
No protection against a struggling Salesforce	Closed	Circuit breaker: after three failures lookups pause for 30 s with a clear message, then resume; Settings shows the paused state.
The same customer is looked up from scratch every time	Closed	A registered lookup for the same identifier within two minutes is reused and audited as <code>reused</code> .
Sign-in renewed every 15 minutes regardless of what Salesforce says	Not a defect	The client-credentials token response carries no expiry, so a conservative fixed cache is the correct choice. Four token calls an hour are negligible against the org's limits.
Signing in is never recorded	Closed	<code>login</code> , <code>login_failed</code> (with reason) and <code>logout</code> are audited (test "records failed sign-ins, sign-ins and sign-outs").
Going online or offline is not recorded	Closed	<code>presence_online</code> and <code>presence_offline</code> with the reason, including heartbeat expiry.
History shows 100 entries, no filter, no paging, no export	Closed / Closed today	Cursor paging, date and action filters, and since today a CSV export of the filtered trail, itself recorded as <code>audit_export</code> .

Verification

Check	Result
Type check and lint	clean
Automated tests (<code>npm test</code>)	147 passed across 12 files: domain rules, route table, API document, browser/server boundary, schema drift, database workflows, API, delivery, security, listener
Environments	Company PostgreSQL 18 server (development and test databases, restricted role), Neon (live data), Render (live site)
End-to-end smoke test on the local server	Health and alerts, sign-in, forced password change, presence, Salesforce sandbox probe, QR invite, guest session and lookup, ticket issue (idempotent), public status, call, TV board, stale version refused, start, offline-mid-service refused, close with note, history, receipt, reports JSON and CSV, audit, walk-in, live event delivered, paging validation, 404s, security headers, sign-out
Load measurement (<code>scripts/load-check.mjs</code>)	Run A (20 agents, 200 customers, 20 connections): check-in of all 200 in 1.3 s, median 959 ms and 95th percentile 1,282 ms under full contention; tick with nobody online 19 ms, with everyone online 96 ms, all 200 assigned; 600 agent actions at median 23 ms, 95th percentile 46 ms, maximum 60 ms. Run B (10 agents, 400 customers): check-in of all 400 in 1.8 s; tick 25 ms and 214 ms; 1,200 actions at median 11 ms, 95th percentile 20 ms, maximum 65 ms. Company PostgreSQL 18 server on a laptop; production hardware will be faster
Live site	health, scheduler heartbeat and alert endpoint healthy; security headers present; unknown paths 404

Reproduce: `npm run typecheck && npm run lint && npm test && npm run build && npm run build:worker`, then `node --env-file=.env.test scripts/load-check.mjs 20 200 20`.

What remains, and who decides

Item	Type	Owner
Routing policy: cross-service fairness, new-member position, cap on uncalled assignments, owner-first threshold, priority flag	Decision	CRM and Collection managers, Product
Retention periods for ticket identifiers and audit events (the job exists, switched off)	Decision	Product, IT
SSO or MFA, and an HR-linked offboarding process	Decision	IT
Production PostgreSQL server; Render's database moved to it	Operations	IT
Salesforce production org, connected app and dedicated integration user	Operations	Salesforce team
Uptime monitor on <code>/api/health/alerts</code> ; production secrets; custom domain	Operations	IT
Device acceptance: phones, printer, TV audio	Operations	CRM team
Consolidate the three CSS files; browser tests	Engineering, non-blocking	Developer

Change log since the review

Commit	Scope
3aac449	Audit of sign-in and presence, walk-in fallback, General Query for customers without units, TV expiry, password confirmation, real 404s, request ids and logging, migration checksums, retention purge, PBKDF2 600,000, unused UI removed
b42b51b	Next.js 16 replaces the beta framework; declared route table with PUT, PATCH and DELETE; connection pool with transactions; server-sent events; shell split; schema snapshot; rate-limit windows
9650936	Restricted <code>qms_app</code> role; alert endpoint; retention job; day rollover; paging validation; forged-address-proof rate limits; migration runner fix; OpenAPI document
549854b	Standard PostgreSQL driver replaces Neon's; CI on a PostgreSQL container
500caae	This response: 45-second presence window, worker in direct database mode, browser/server boundary test, error boundaries, identifier opt-in on exports, audit export, bootstrap-password alert, TV announcement at load, load measurement script

Design document: "Samana QMS – Demo Flow and Technical Design", sections 3, 7, 8, 9, 11, 12 and 14 track the same state. Checklist: [docs/review-checklist-2026-09-21.md](#) .